

MITM Attack

Cybersecurity Internship – Phase 1, Task 9

Name: Parmar Rakesh

Date: 24, AUG, 2025

Internship Program: Cybersecurity Internship – UJAR TECH

What is a man-in-the-middle (MITM) attack?

A man-in-the-middle (MITM) attack is a [cyberattack\[26\]](#) in which a hacker steals sensitive information by eavesdropping on communications between two online targets such as a user and a web application.

After stealthily placing themselves in the middle of two-party communications, MITM attackers intercept sensitive data such as credit card numbers, account information and login credentials. Hackers then use that information to commit other cybercrimes such as making unauthorized purchases, hijacking financial accounts and identity theft.

In addition to exchanges between a user and an application, an MITM attacker might also eavesdrop on private communications between two people. In this scenario, the attacker diverts and relays messages between the two people, sometimes altering or replacing messages to control the conversation.

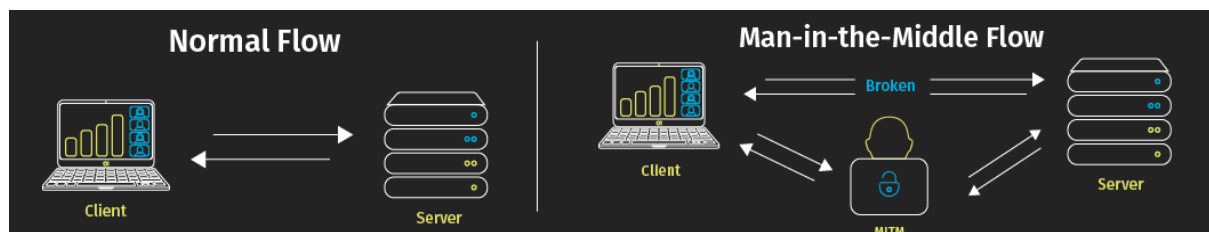
Some organizations and cybersecurity experts are moving away from the term “man-in-the-middle” because some might consider the language potentially biased. The term might also fail to capture instances where the entity in the middle is a bot, device or malware rather than a person.

Alternative terms for this type of cyberattack include machine-in-the-middle, on-path attack, adversary-in-the-middle (AITM) and manipulator-in-the-middle.

How does a man-in-the-middle attack work?

Vulnerabilities across networks, web browsers, email accounts, user behaviors and security protocols are the starting points of MITM attacks. Cybercriminals exploit these weaknesses to insert themselves between users and trusted applications so they can control communications and intercept data in real time.

Phishing attacks are one common means of entry for MITM attackers. By clicking on a malicious link in an email, a user can unknowingly launch a man-in-the browser attack. MITM attackers often rely on this tactic to infect a user’s web browser with malware that enables them to make covert changes to web pages, manipulate transactions and spy on the user’s activity.



Another common source of MITM attacks is public wifi hotspots. Public wifi routers have fewer security protocols than home or workplace wifi routers. This makes it easier for nearby

users to connect with the network. But it also makes it easier for hackers to compromise the router so they can eavesdrop on internet traffic and collect user data.

MITM attackers sometimes create their own malicious public wifi networks to lure unsuspecting users and harvest their personal data.

MITM attackers might also create fake websites that appear legitimate but are actually collecting critical data such as login credentials. Hackers can then use those credentials to log in to user accounts on authentic websites. Or they might use the fake website to deceive users into making payments or transferring funds.

Stages of a man-in-the-middle attack

Man-in-the-middle attacks require cybercriminals to: 1) intercept the data that is passing between their two targets and 2) decrypt that information.

Interception

In order to get in the middle of two communicating targets, such as a user and a web application, an attacker must intercept the data traveling between the two. The attacker then relays that diverted information between the targets as if normal communications are underway so that victims don't suspect a thing.

Decryption

Most internet communications today are encrypted, so any data a MITM attacker intercepts will most likely need to be decrypted before the attacker can use it. Attackers can decrypt data by stealing encryption keys, running brute-force attacks or using specialized MITM attack techniques.

Man-in-the-middle attack techniques

Attackers use a variety of techniques to intercept and decrypt data during MITM attacks. Common techniques include:

IP spoofing: Internet Protocol (IP) addresses identify online entities such as websites, devices and email addresses. MITM attackers alter or 'spoof' their IP addresses so it appears a user is communicating with a genuine host when they are actually connected to a malicious source.

ARP spoofing or ARP cache poisoning: The Address Resolution Protocol (ARP) connects an IP address with the correct Media Access Control (MAC) address on a local area network. By spoofing the ARP address, an attacker can route this connection to their own MAC address to extract information.

DNS spoofing: The DNS connects the domain names of websites to their assigned IP addresses. By changing a domain name in the DNS records, an MITM attacker can route users away from a legitimate site to a fraudulent website.

HTTPS spoofing: Hypertext Transfer Protocol Secure (HTTPS) ensures secure communications by encrypting the data that travels back and forth between a user and a website. MITM attackers will secretly route users to a standard HTTP page without encryption so they can access unprotected data.

SSL hijacking: Secure Sockets Layers (SSL) is the technology that provides authentication and encryption between a web browser and a web server using SSL certificates. MITM attackers use a fake SSL certificate to hijack this process and intercept data before it can be encrypted.

SSL stripping: This technique takes place when a website accepts incoming HTTP connections before directing that traffic to secure HTTPS connections. MITM attackers disrupt this transition process so they can access unencrypted data before it moves to a secure HTTPS connection.

Introduction to Ettercap

Ettercap is a comprehensive suite for man-in-the-middle (MiTM) attacks. It supports active and passive dissection of many protocols and includes various features for network and host analysis. As with all tools used for ethical hacking, it's crucial to have proper authorization before conducting any attacks.

Installing Ettercap

Before diving into the attacks, ensure that Ettercap is installed on your system. On Kali Linux, you can install it using the following command:

- **sudo apt-get install ettercap-graphical**

ARP Poisoning using Ettercap

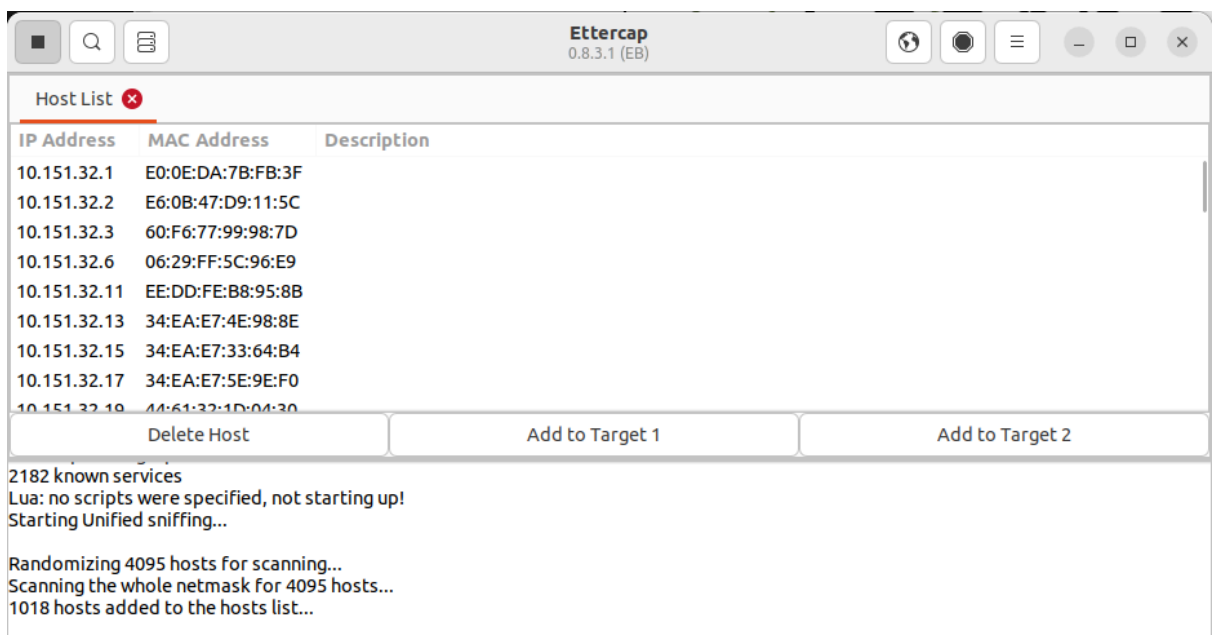
ARP Poisoning is one of the most common MiTM attacks. Here's how you can perform it using Ettercap:

1. Open your terminal and type the following command to start Ettercap in graphical mode:

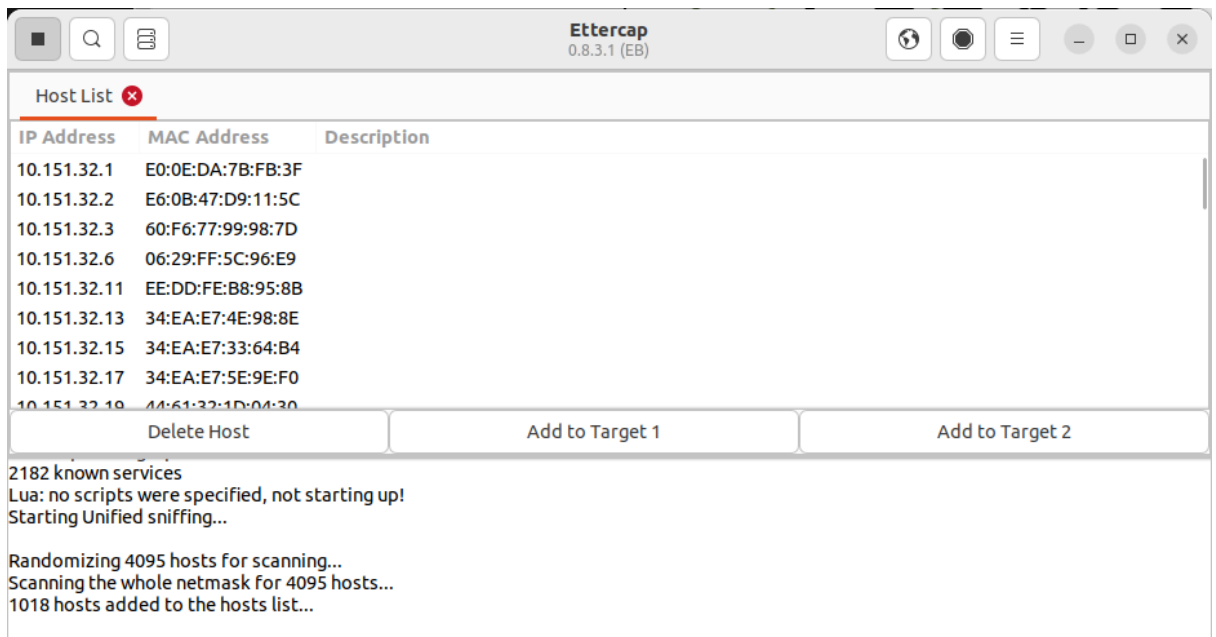
2. `sudo ettercap -G` Click on "Primary Interface", and choose your network interface (e.g., `eth0`, `wlan0`) you want to use and click "OK".



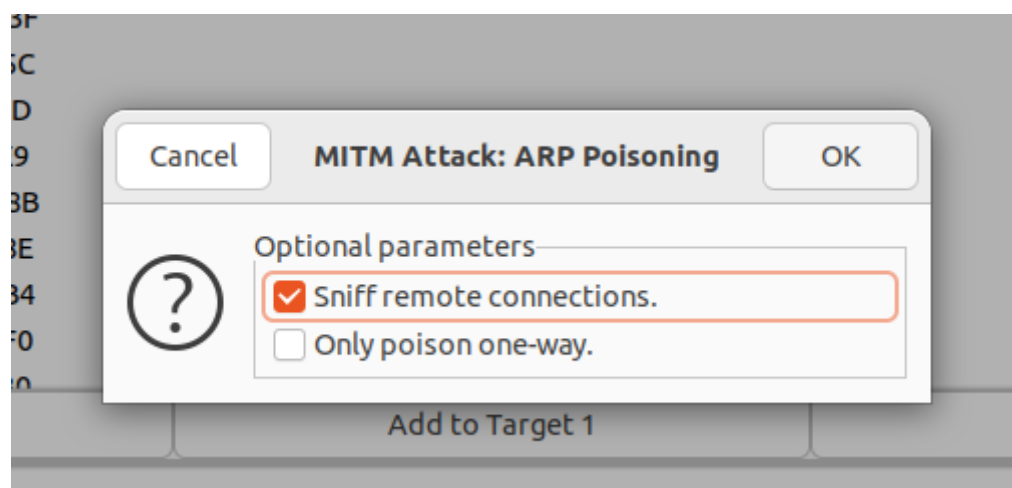
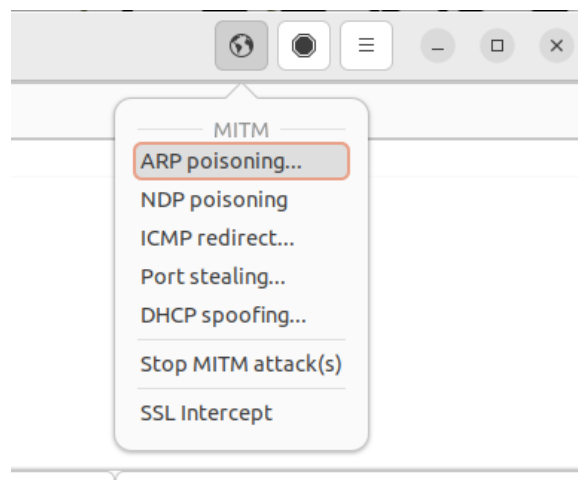
3. Then click on the Sniff button, or select "Sniff" > "Unified Sniffing".
4. Go to "Hosts" > "Scan for hosts" to discover devices on the network.



5. After scanning, go to "Hosts" > "Host List" to view the discovered devices.



6. (Optional Step) Select the target hosts. You can set one as the target 1 and another as target 2.
7. Now, go to "Mitm" > "ARP poisoning". Check "Sniff remote connections" and click "OK".



8. Finally, start the attack by clicking "Start" > "Start Sniffing".

Remember to stop the attack once done and always ensure you have permission before conducting any tests.

DNS Spoofing using Ettercap

DNS Spoofing can redirect traffic from legitimate servers to malicious ones. Here's how to perform DNS Spoofing with Ettercap:

1. Edit the `etter.dns` file to specify the domain you want to spoof:
 - **`sudo nano /etc/ettercap/etter.dns`**
2. Add an entry like: "www.example.com A 192.168.x.x", where 192.168.x.x is the IP of the malicious server.
3. Save and close the file.
4. Start Ettercap with the following command:
 - **`sudo ettercap -T -q -i [interface] -P dns_spoof -M arp:remote /target1// /target2//`**

Replace [interface] with your network interface, and target1 and target2 with the IP addresses of your targets.